PENETRATION TESTING REPORT

MEDIROZA GENERAL HOSPITAL

WEEK 4 | CYBERSECURITY & ETHICAL HACKING | NETWORKWALKS

Pentester Name	Shiwani Dodke
Program/Batch	B083 | NetworkWalks
Date	20 October 2026
Client	Mediroza General Hospital
Target	https://medirozahospital.com
Engagement Type	Black-box Penetration Test
Duration	5 Days
Permission Secured?	Yes — written authorisation granted by the client for all milestones (confirmed in the project brief)
Milestones Covered	M1: Initial Access M2: Data Extraction (Cracking) M3: Critical Data Exposure M4: Reporting

1. Liability Disclaimer

The activities described in this report were carried out strictly within an authorised, controlled training engagement assigned by NetworkWalks. Written permission to test https://medirozahospital.com was granted for every milestone of this project, as stated in the official project brief. All techniques used here must never be applied to any system without explicit written permission from its owner.

2. Executive Summary

This engagement was a black-box penetration test against Mediroza General Hospital's web infrastructure. Testing uncovered a complete attack chain: a flawed login mechanism allowed an attacker to both confirm valid usernames and bypass authentication entirely using SQL injection. This exposed three confidential patient lab reports, each protected only by a weak, guessable password. Cracking one of these reports revealed metadata left behind by an IT administrator referencing a forgotten backup folder on the server. That folder was found to have directory listing enabled, exposing a full HR and shareholder database backup containing staff salaries, national ID numbers, and company ownership details in plain text.

Overall risk to the client is rated Critical. The combination of an exploitable authentication bypass and an exposed, unprotected database backup represents a severe breach of patient confidentiality and employee/company data, with potential regulatory, financial and reputational consequences.

3. Scope and Methodology

Target: https://medirozahospital.com

Scope: Full black-box penetration test limited strictly to the target domain. No social engineering, no denial-of-service testing, and no testing outside the agreed scope.

Approach: Reconnaissance → entry-point identification → authentication testing → exploitation → data extraction → deep analysis of retrieved evidence → reporting

Tools Used

Tool	Purpose
Kali Linux	Primary testing platform for recon and exploitation
whois / nslookup	Domain registration and DNS resolution lookups
whatweb / curl	Web technology fingerprinting and HTTP header inspection
gobuster	Directory and file brute-forcing to discover hidden paths
theHarvester	Passive OSINT gathering (emails, subdomains)
wpscan	WordPress enumeration (version, plugins, themes, users)
Browser (manual testing)	Login form testing: username enumeration and SQL injection
NetworkWalks Hash Calculator	Extracting crackable hashes from encrypted PDFs
NetworkWalks Password Cracker	Dictionary attacks against PDF password hashes
qpdf	Decrypting a password-recovered PDF to a clean, readable copy
exiftool	Reading hidden file metadata (Author, Comments, etc.)

Tool	Purpose
wget	Downloading exposed files from the server

4. Findings and Proof of Exploitation

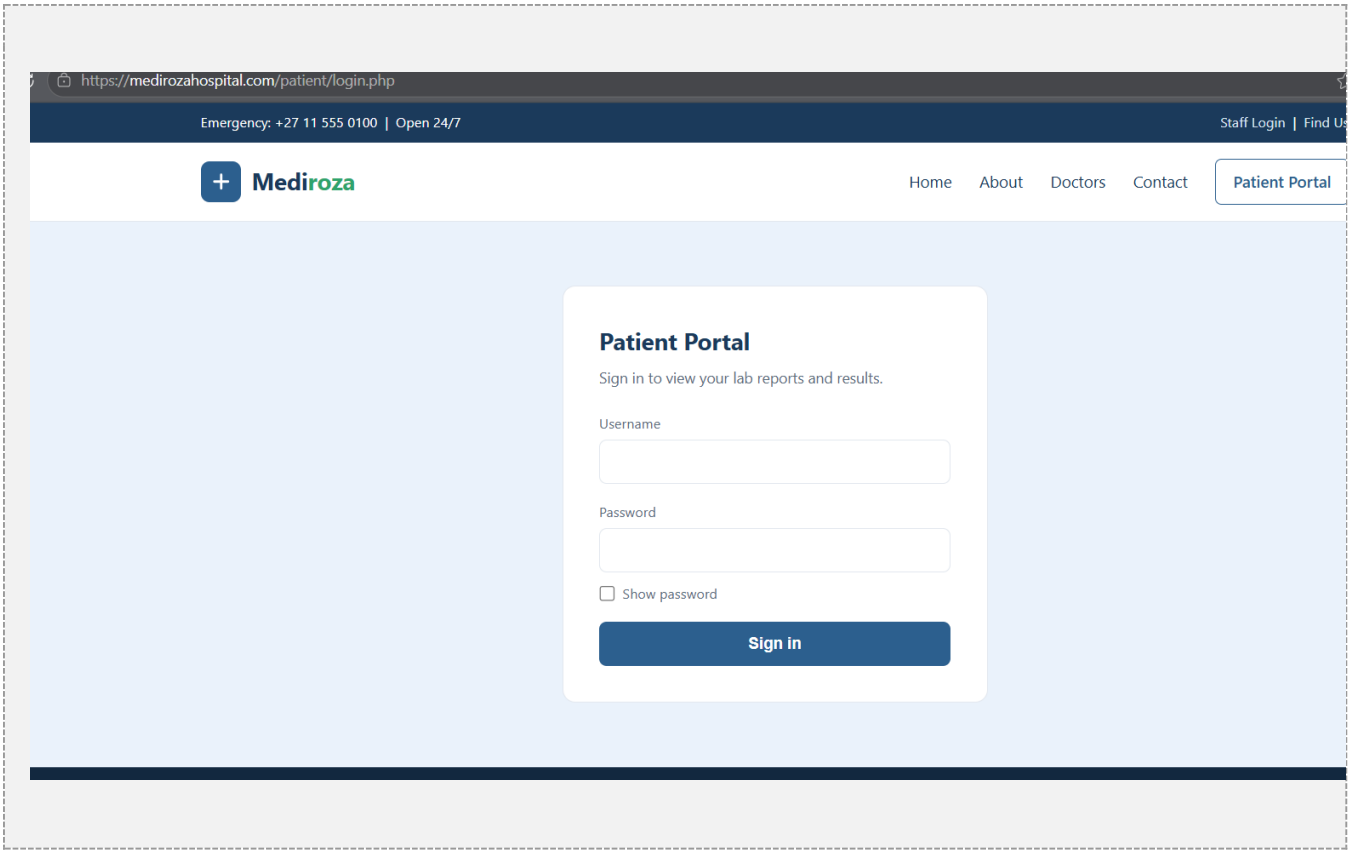
4.1 Initial Access

Reconnaissance began with a check of the site's robots.txt file, which disallowed three folders from search indexing: /patient/, /staff/, and /old/. This is a common misconfiguration — robots.txt is meant to guide search engines, not restrict access, so it often reveals exactly the folders an operator wanted hidden.

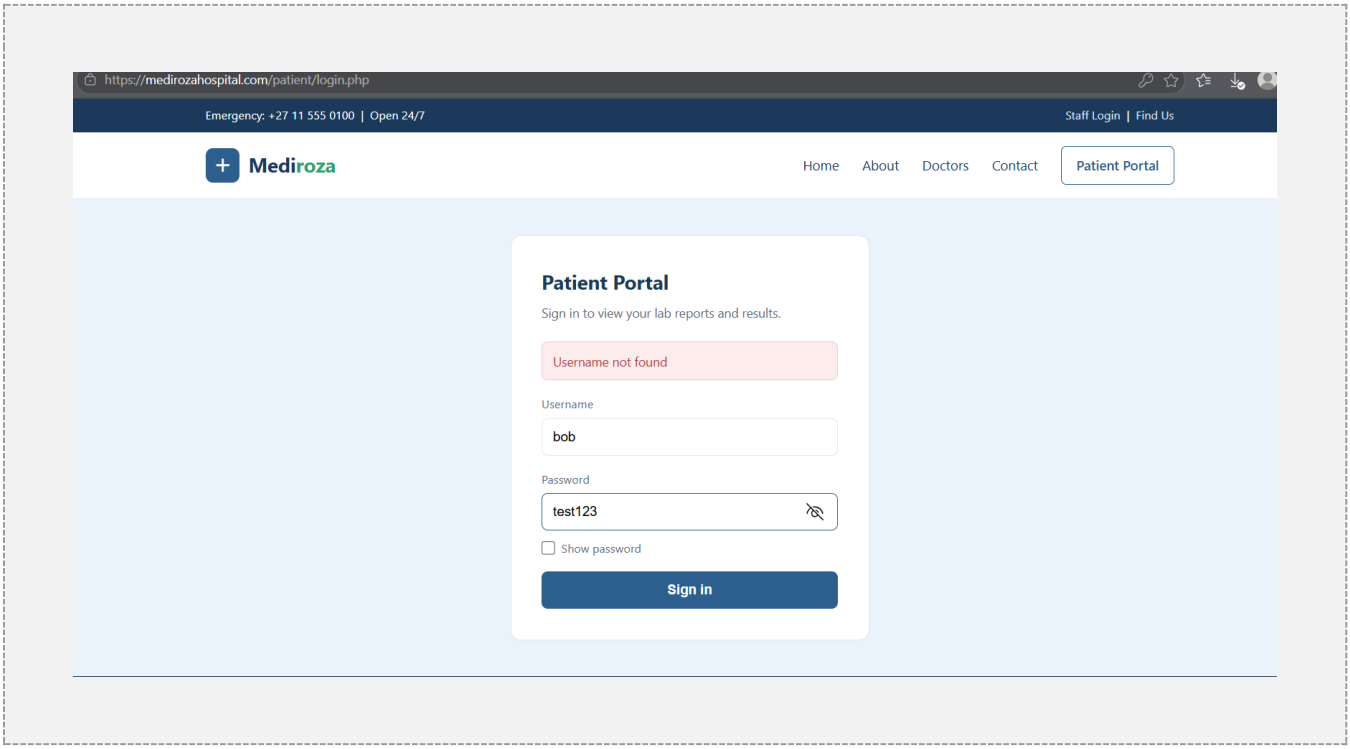
```
curl https://medirozahospital.com/robots.txt
```



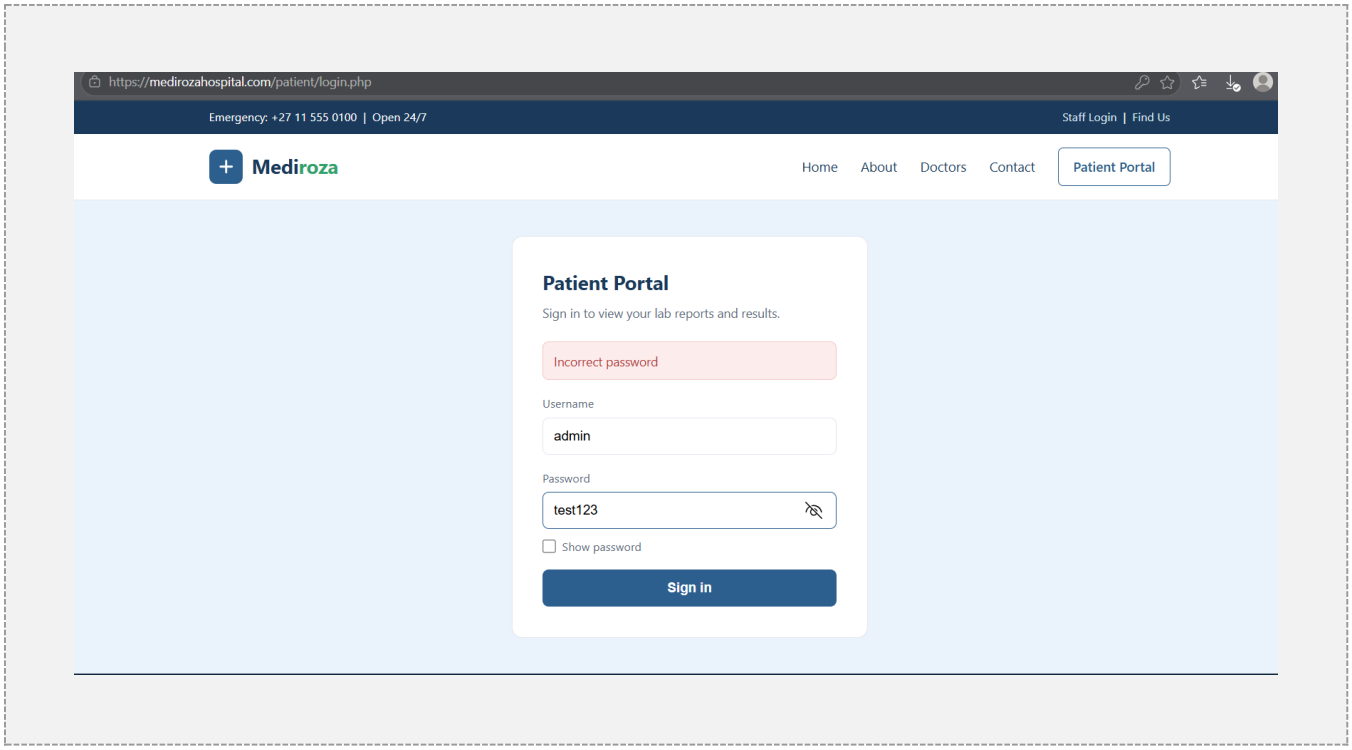
The /patient/ folder led to a login page at /patient/login.php.



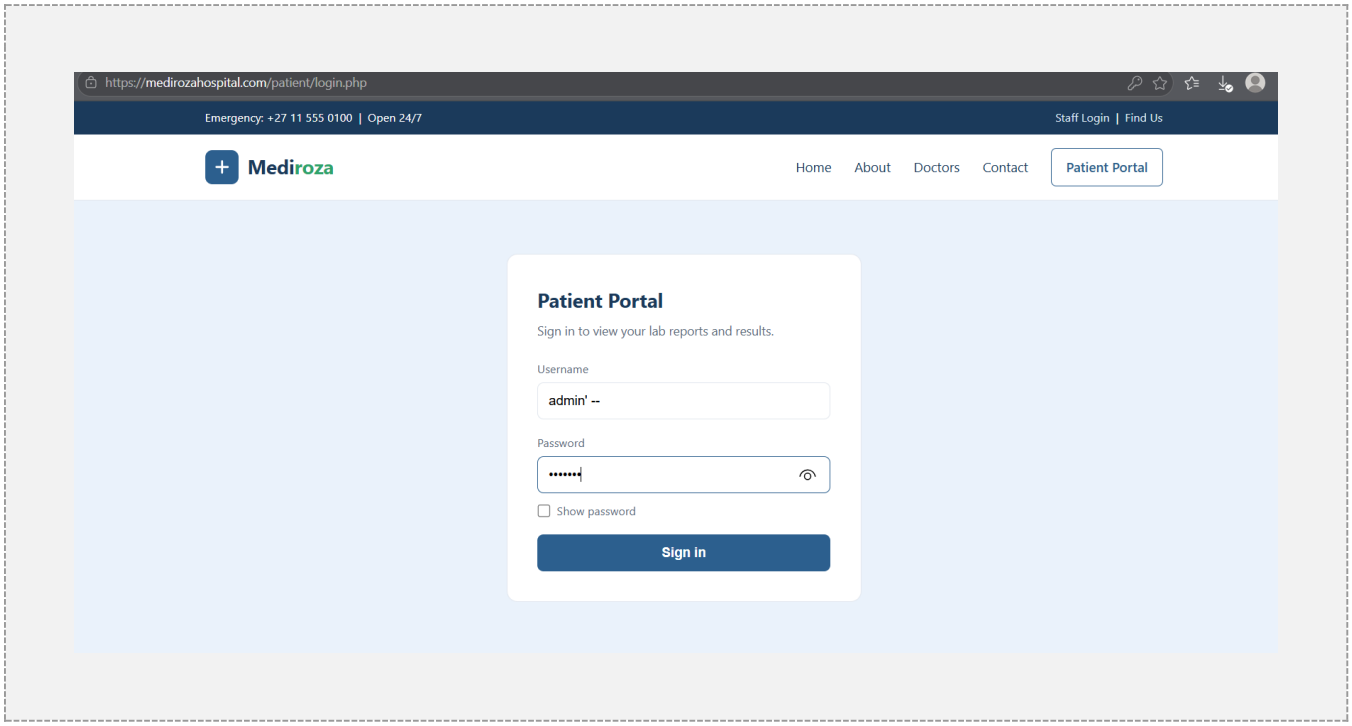
Testing the login form with a fake username (bob) and a real-looking one (admin) produced two different error messages — "Username not found" versus "Incorrect password." This confirms the application leaks whether a username exists, a vulnerability known as username enumeration.



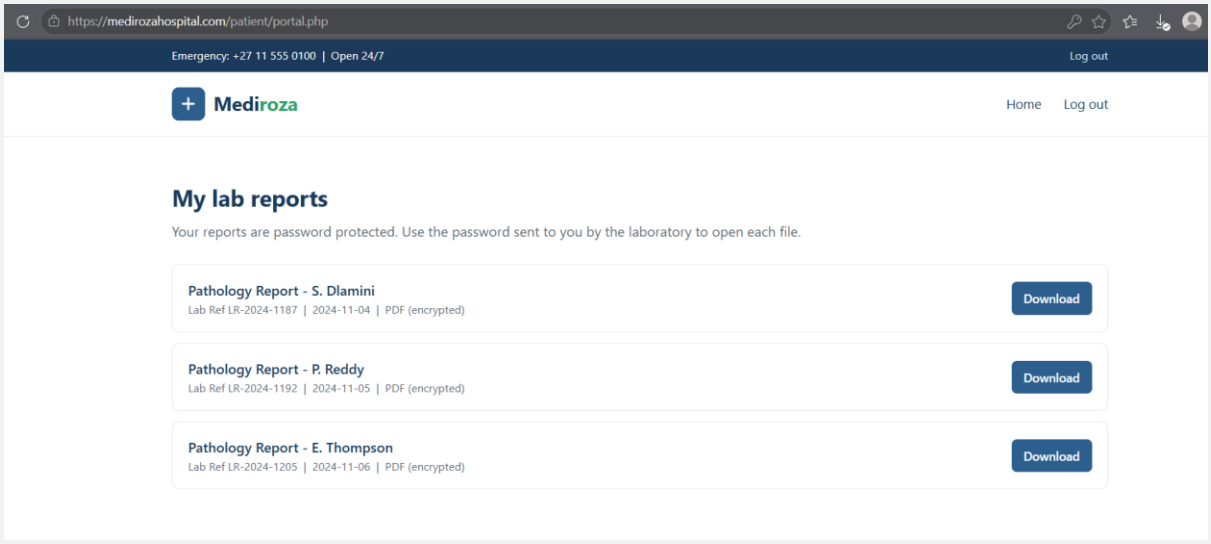
Submitting a single quote in the username field (admin') triggered a raw MySQL syntax error, confirming the login form does not sanitise user input and is vulnerable to SQL injection.



Using the payload admin' -- in the username field (with any password) bypassed authentication entirely by commenting out the password check in the underlying SQL query. This granted full access to the patient portal.

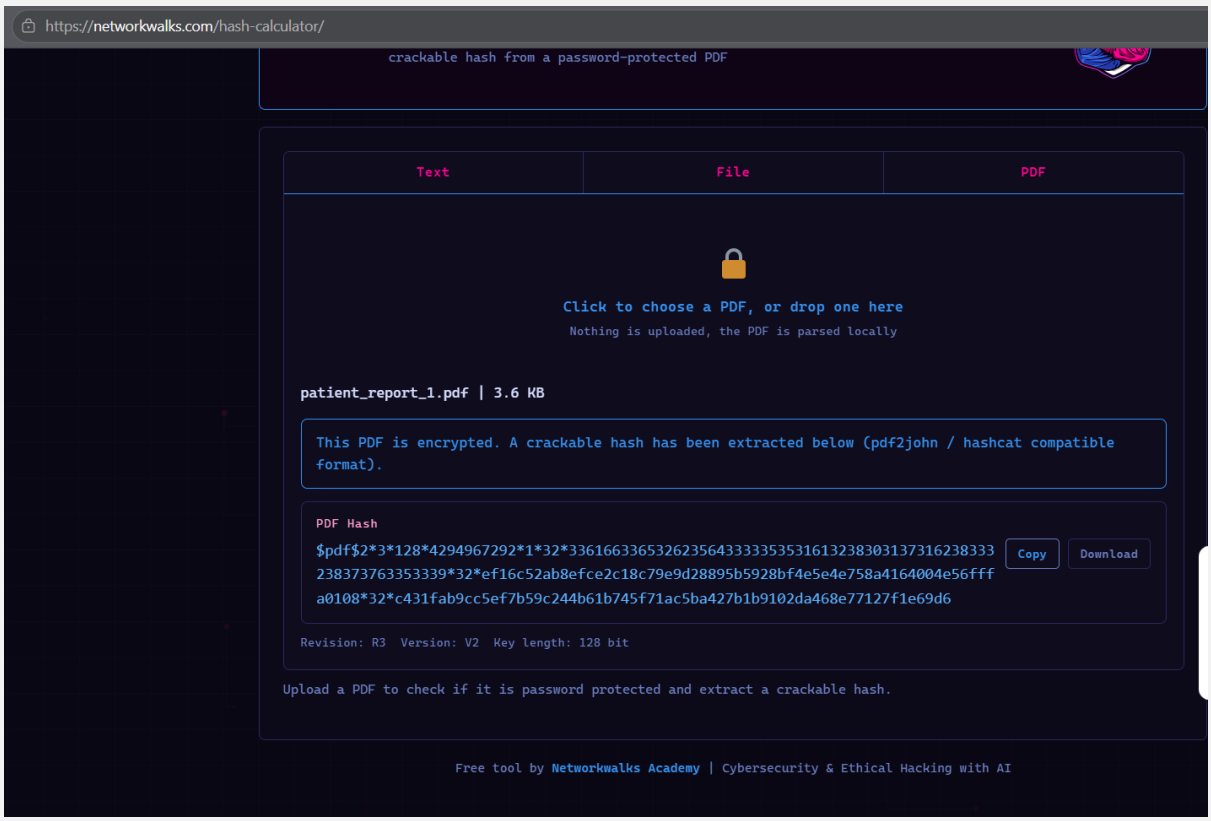


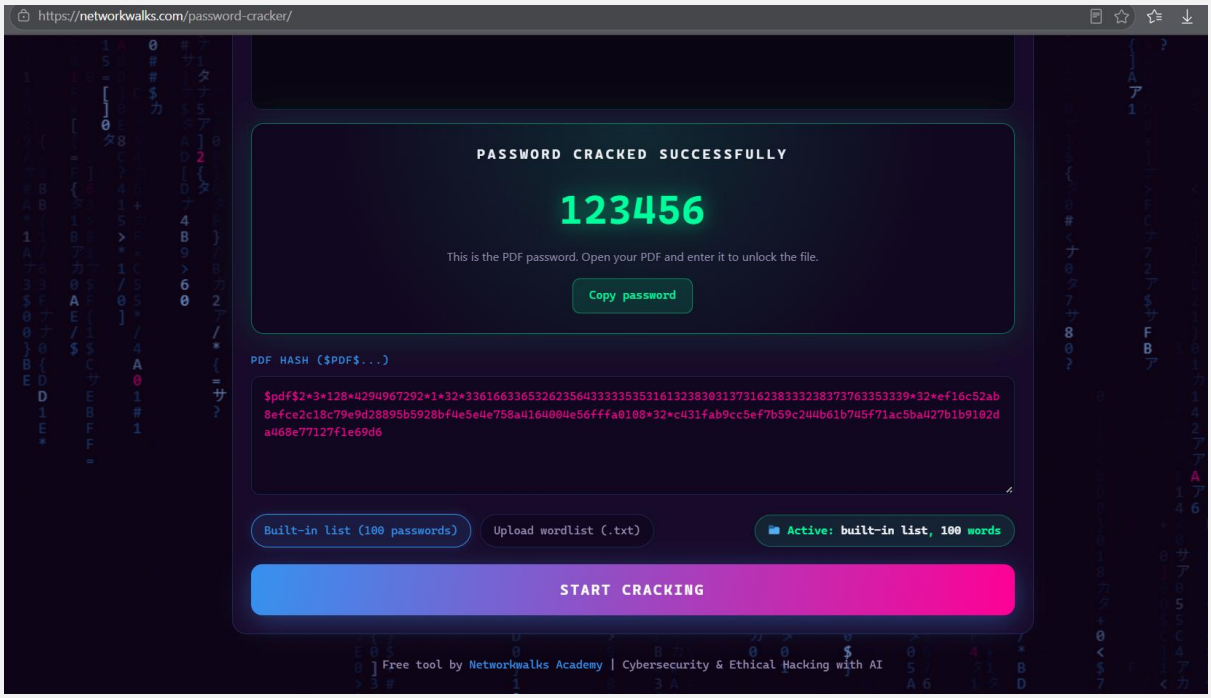
The portal exposed 3 confidential patient lab report PDFs, all of which were downloaded as proof of access.

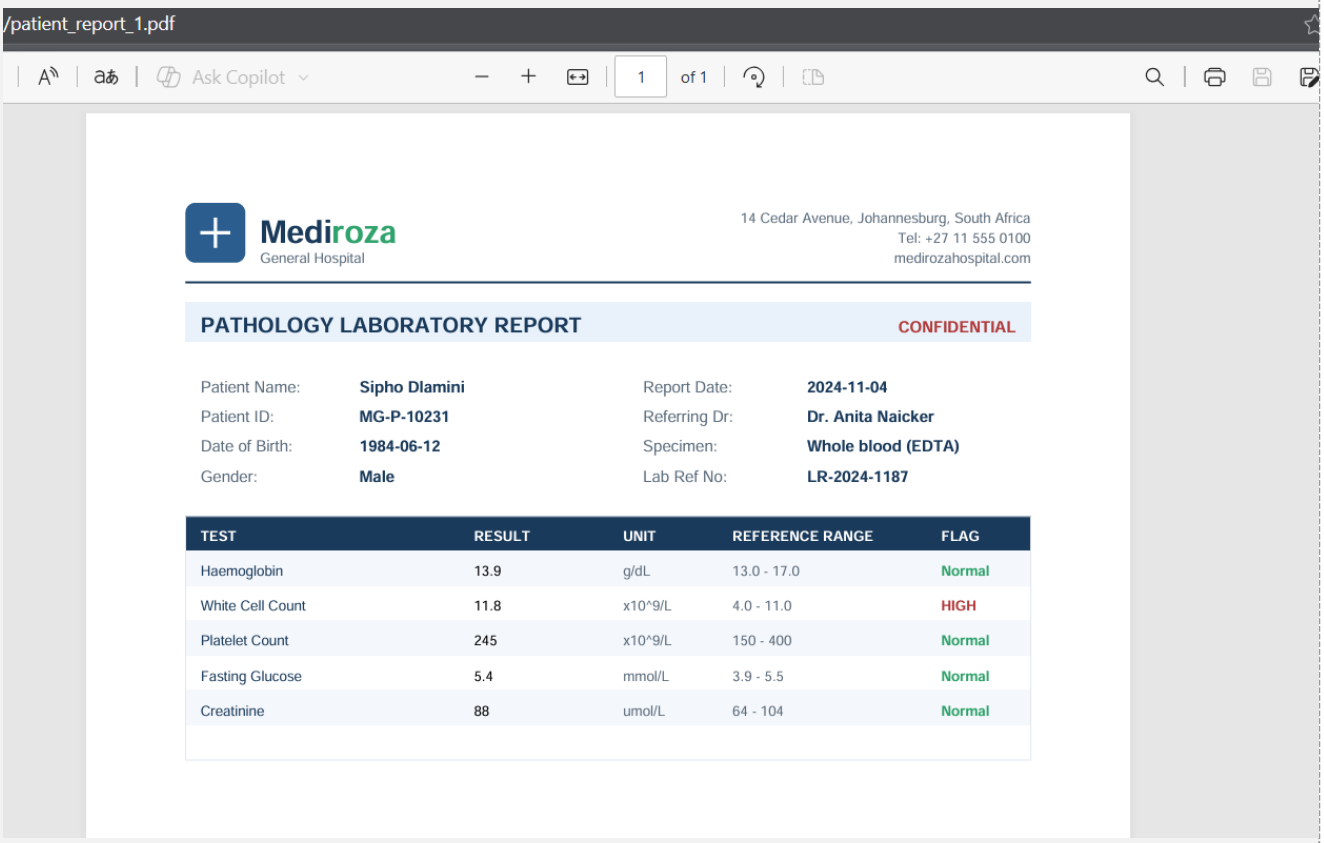


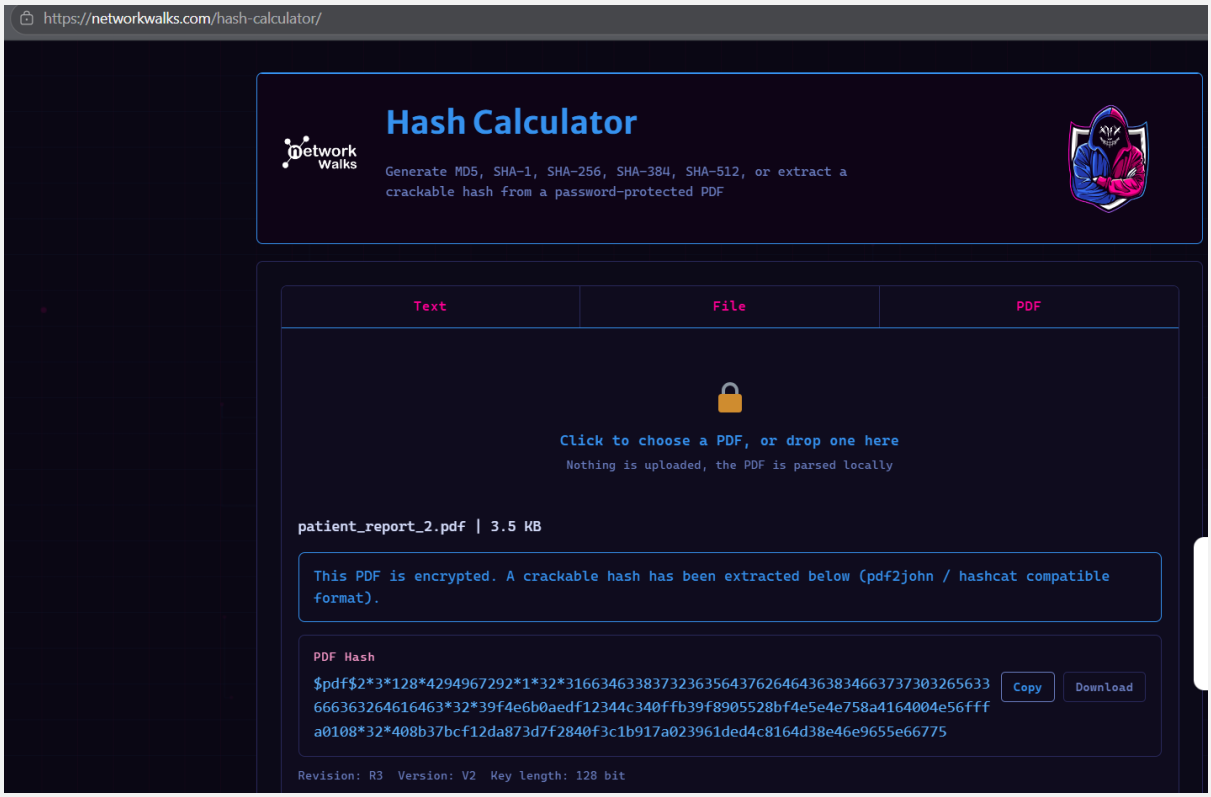
4.2 Cracking the Encryption

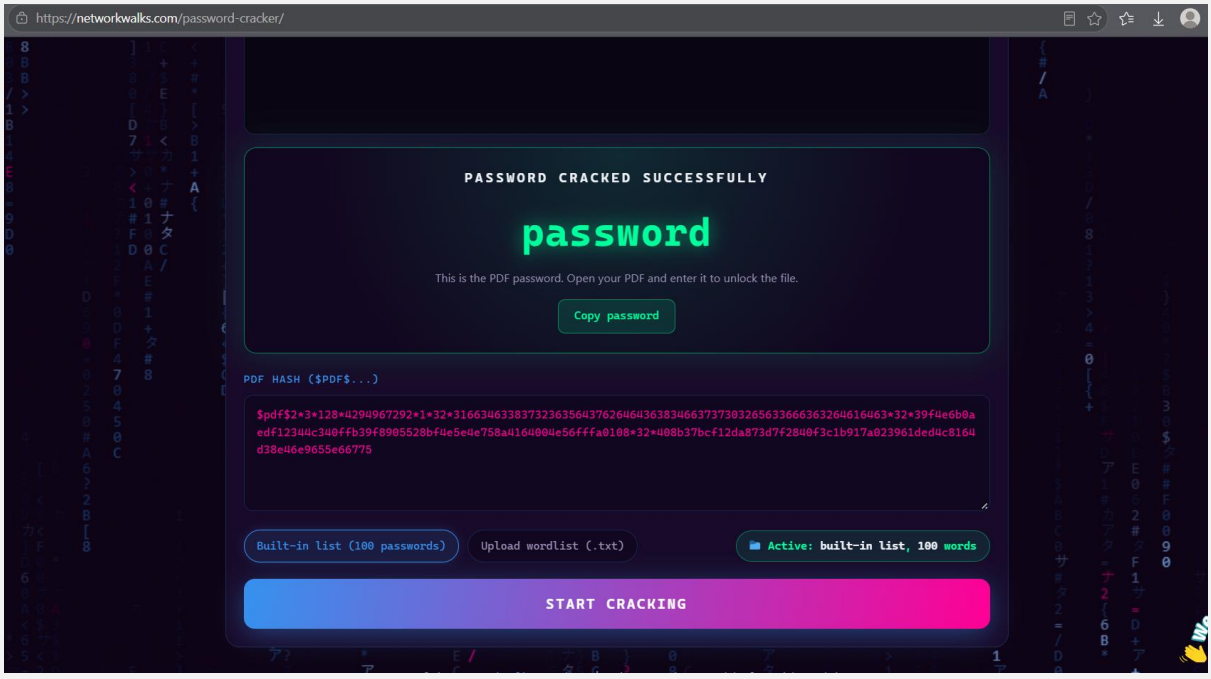
Each PDF was password-protected. A crackable hash was extracted from each file using the NetworkWalks Hash Calculator, then run through the NetworkWalks Password Cracker using a dictionary attack.

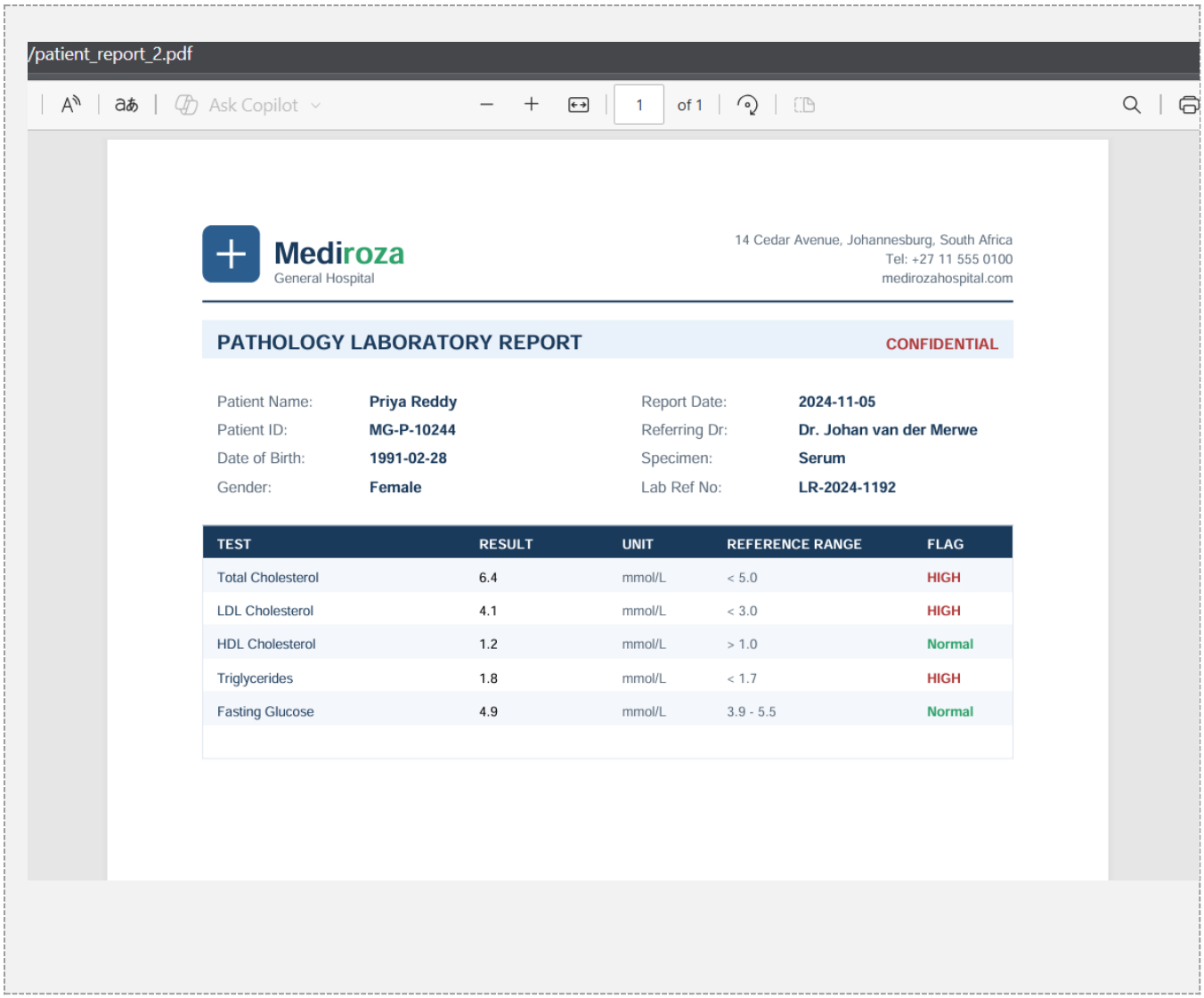



https://networkwalks.com/password-cracker/
PASSWORD CRACKED SUCCESSFULLY
123456
This is the PDF password. Open your PDF and enter it to unlock the file.
Copy password
PDF HASH (PDF...)
pdf2*3*128*4294967292*1*32*3361663365326235643333353531613238303137316238333238373763353339*32*ef16c52ab8efce2c18c79e9d28895b5928bf4e5e4e758a4164004e56fffa0108*32*c431fab9cc5ef7b59c244b61b745f71ac5ba427b1b9102da468e77127f1e69d6
Built-in list (100 passwords)
Upload wordlist (.txt)
Active: built-in list, 100 words
START CRACKING
Free tool by Networkwalks Academy | Cybersecurity & Ethical Hacking with AI


/patient_report_1.pdf
Ask Copilot
1
of 1
Mediroza
General Hospital
14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com
PATHOLOGY LABORATORY REPORT
CONFIDENTIAL
Patient Name: Sipho Dlamini
Patient ID: MG-P-10231
Date of Birth: 1984-06-12
Gender: Male
Report Date: 2024-11-04
Referring Dr: Dr. Anita Naicker
Specimen: Whole blood (EDTA)
Lab Ref No: LR-2024-1187
TEST | RESULT | UNIT | REFERENCE RANGE | FLAG
Haemoglobin | 13.9 | g/dL | 13.0 - 17.0 | Normal
White Cell Count | 11.8 | x10^9/L | 4.0 - 11.0 | HIGH
Platelet Count | 245 | x10^9/L | 150 - 400 | Normal
Fasting Glucose | 5.4 | mmol/L | 3.9 - 5.5 | Normal
Creatinine | 88 | umol/L | 64 - 104 | Normal

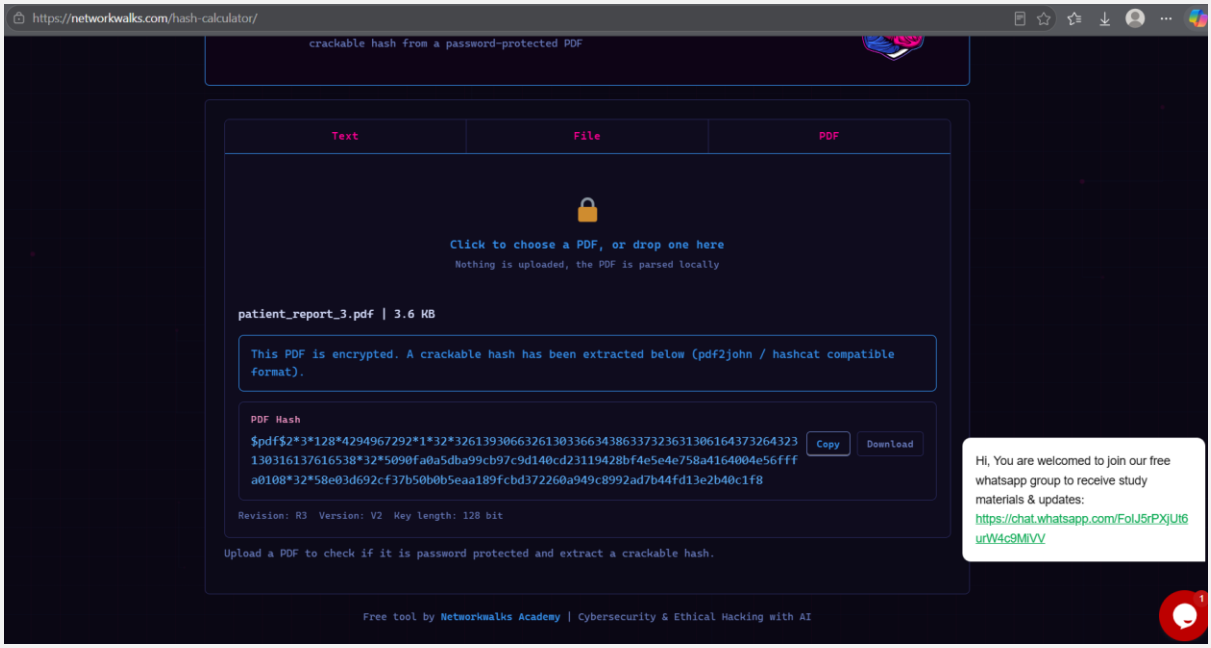

https://networkwalks.com/hash-calculator/
Hash Calculator
Generate MD5, SHA-1, SHA-256, SHA-384, SHA-512, or extract a crackable hash from a password-protected PDF
Text
File
PDF
Click to choose a PDF, or drop one here
Nothing is uploaded, the PDF is parsed locally
patient_report_2.pdf | 3.5 KB
This PDF is encrypted. A crackable hash has been extracted below (pdf2john / hashcat compatible format).
PDF Hash
pdf2*3*128*4294967292*1*32*3166346338373236356437626464363834663737303265633666363264616463*32*39f4e6b0aedf12344c340ffb39f8905528bf4e5e4e758a4164004e56fffa0108*32*408b37bcf12da873d7f2840f3c1b917a023961ded4c8164d38e46e9655e66775
Copy
Download
Revision: R3 Version: V2 Key length: 128 bit

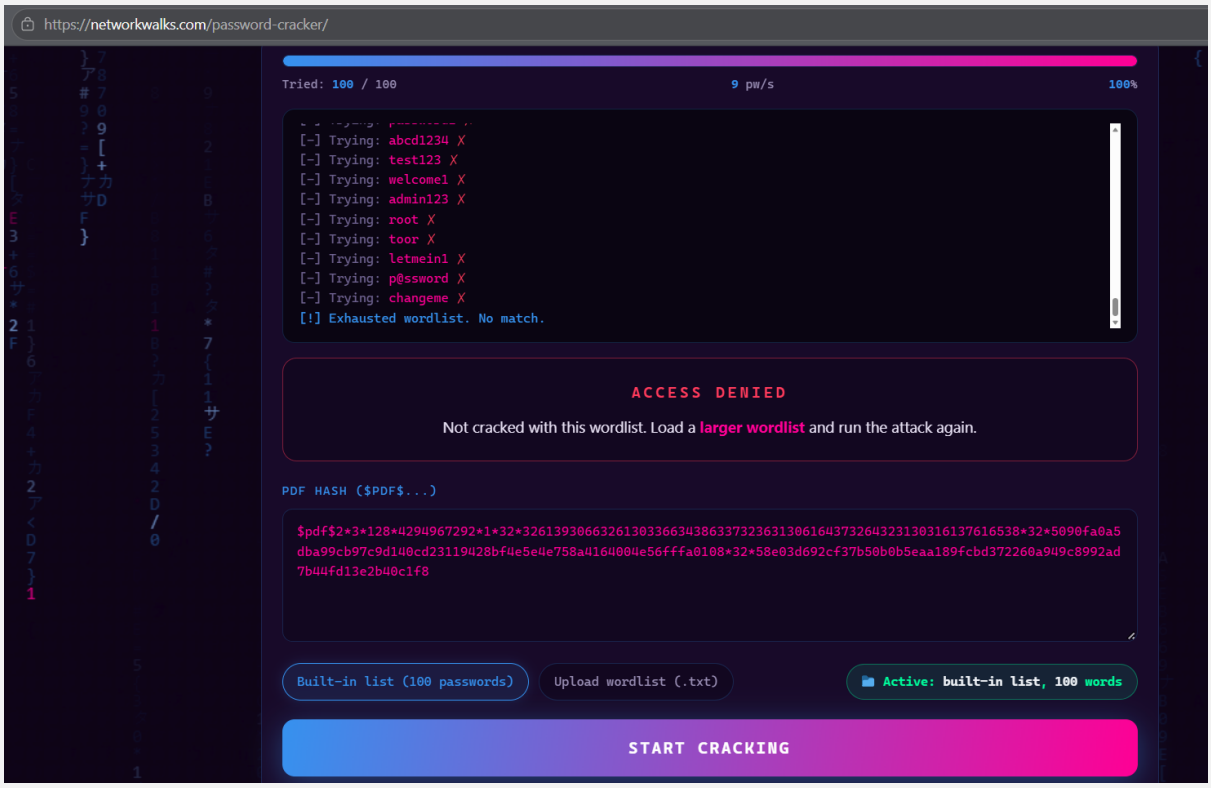

https://networkwalks.com/password-cracker/
PASSWORD CRACKED SUCCESSFULLY
password
This is the PDF password. Open your PDF and enter it to unlock the file.
Copy password
PDF HASH (PDF...)
pdf2*3*128*4294967292*1*32*3166346338373236356437626464363834663737303265633666363264616463*32*39f4e6b0aedf12344c340ffb39f8905528bf4e5e4e758a4164004e56fffa0108*32*408b37bcf12da873d7f2840f3c1b917a023961ded4c8164d38e46e9655e66775
Built-in list (100 passwords)
Upload wordlist (.txt)
Active: built-in list, 100 words
START CRACKING



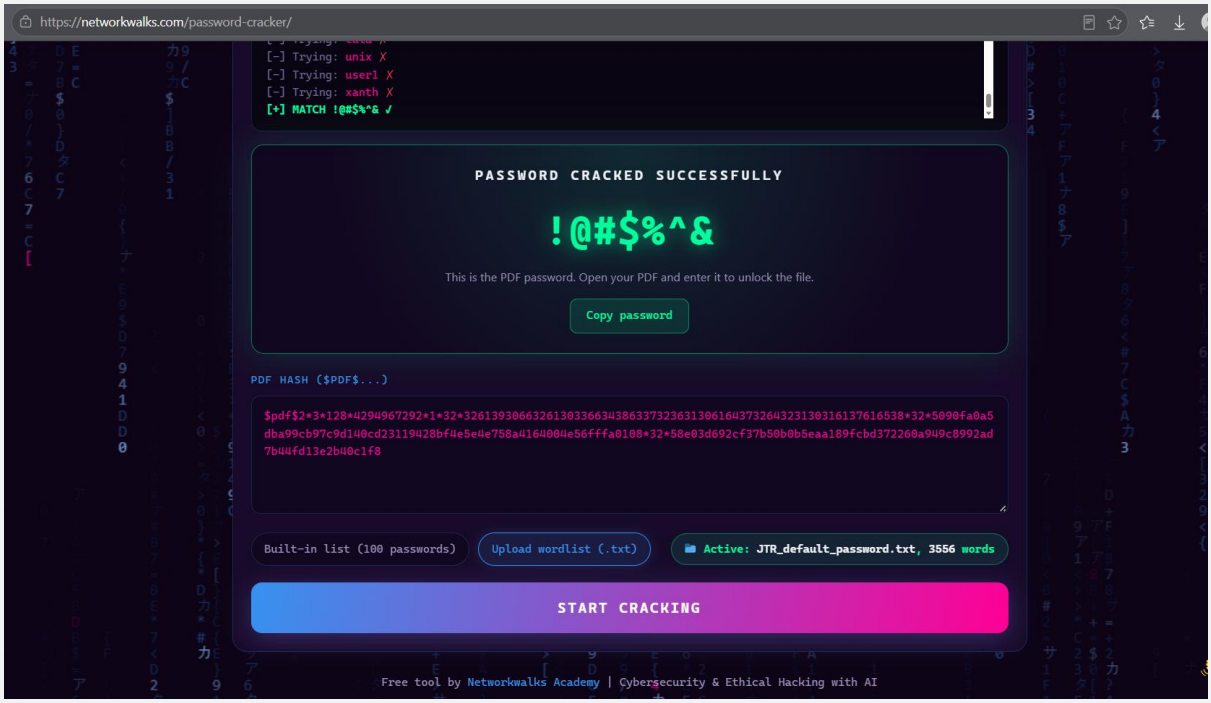
patient_report_1.pdf: Cracked with the built-in common-password list — password: 123456

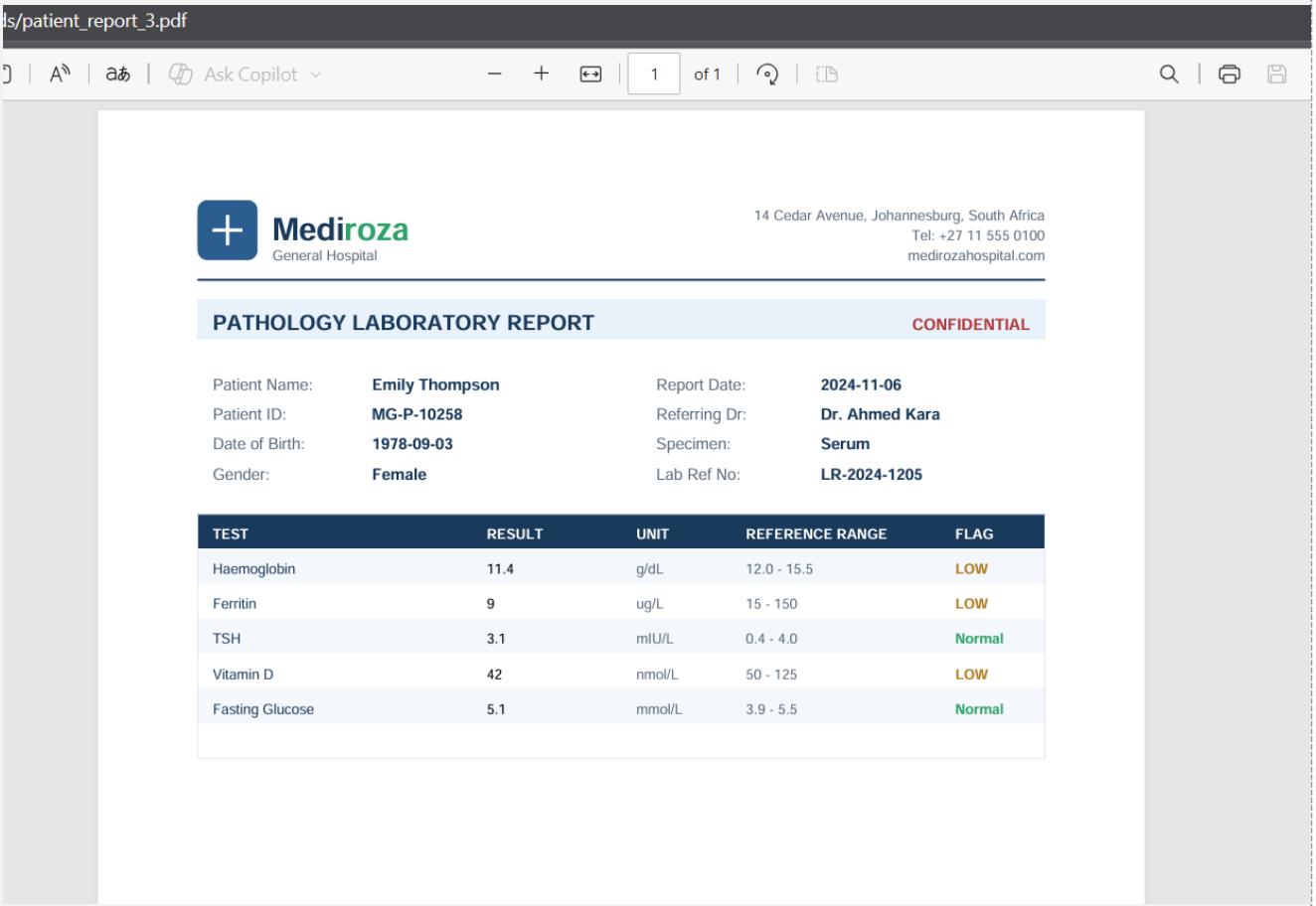
patient_report_2.pdf: Cracked with the built-in common-password list — password: password





patient_report_3.pdf did not crack with the built-in list (“Exhausted wordlist. No match.”). Switching to a larger wordlist (JTR) succeeded.


https://networkwalks.com/password-cracker/
[-] Trying: unix ✗
[-] Trying: user1 ✗
[-] Trying: xanth ✗
[+] MATCH !@#$%^& ✓
PASSWORD CRACKED SUCCESSFULLY
!@#$%^&
This is the PDF password. Open your PDF and enter it to unlock the file.
Copy password
PDF HASH (PDF...)
pdf2*3*128*4294967292*1*32*32613930663261303366343863373236313061643732643231303161376165 38*32*5090fa0a5dba99cb97c9d140cd23119428bf4e5e4e758a4164004e56fffa0108*32*58e03d692cf37b50b0b5eaa189fcbd372260a949c8992ad7b44fd13e2b40c1f8
Built-in list (100 passwords)
Upload wordlist (.txt)
Active: JTR_default_password.txt, 3556 words
START CRACKING
Free tool by Networkwalks Academy | Cybersecurity & Ethical Hacking with AI


ds/patient_report_3.pdf
Ask Copilot
1
of 1
Mediroza
General Hospital
14 Cedar Avenue, Johannesburg, South Africa
Tel: +27 11 555 0100
medirozahospital.com
PATHOLOGY LABORATORY REPORT
CONFIDENTIAL
Patient Name: Emily Thompson
Patient ID: MG-P-10258
Date of Birth: 1978-09-03
Gender: Female
Report Date: 2024-11-06
Referring Dr: Dr. Ahmed Kara
Specimen: Serum
Lab Ref No: LR-2024-1205
TEST | RESULT | UNIT | REFERENCE RANGE | FLAG
Haemoglobin | 11.4 | g/dL | 12.0 - 15.5 | LOW
Ferritin | 9 | ug/L | 15 - 150 | LOW
TSH | 3.1 | mIU/L | 0.4 - 4.0 | Normal
Vitamin D | 42 | nmol/L | 50 - 125 | LOW
Fasting Glucose | 5.1 | mmol/L | 3.9 - 5.5 | Normal

patient_report_3.pdf: Cracked with the JTR wordlist — password: !@#$%^&

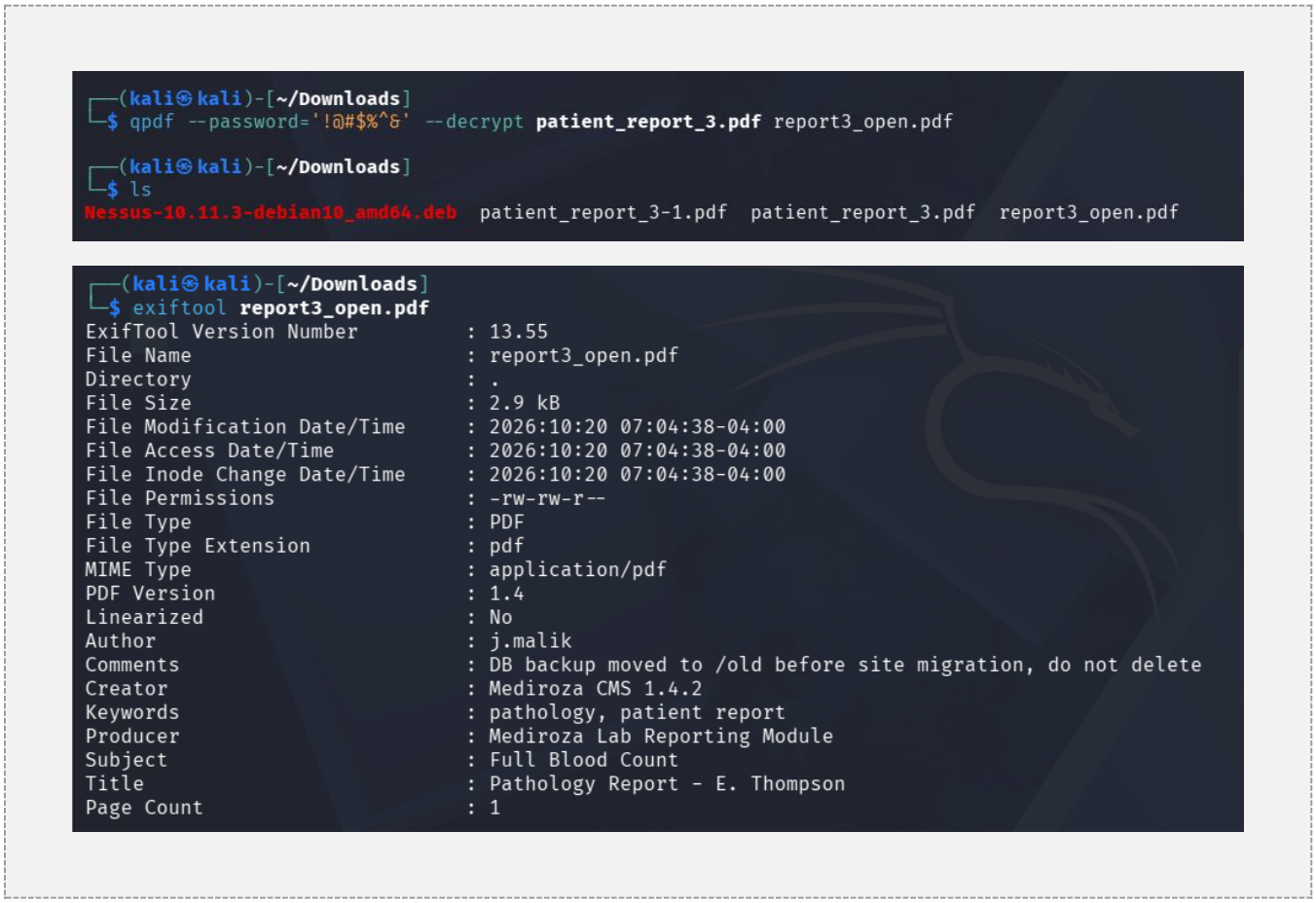
This demonstrates that password strength directly determines how quickly a file can be cracked — common/short passwords fall to small wordlists, while slightly more complex ones require larger, more targeted lists.

```
qpdf --password='!@#$%^&' --decrypt patient_report_3.pdf report3_open.pdf
```

4.3 Critical Data Exposure

Running exiftool against the unlocked copy of report 3 revealed hidden metadata not visible in the PDF viewer, including an Author field and an internal comment.

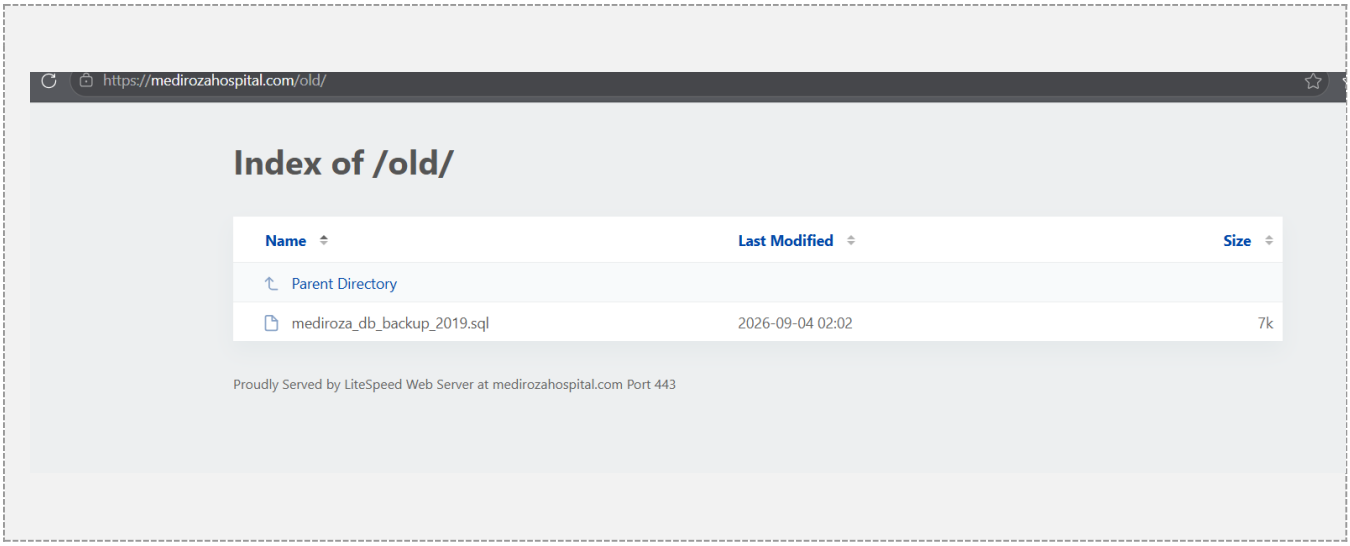
```
exiftool report3_open.pdf
```



Author: j.malik

Comment: "DB backup moved to /old before site migration, do not delete"

This metadata directly referenced the /old/ folder — the same folder flagged in the very first robots.txt check during Milestone 1. Visiting it confirmed directory listing was enabled, exposing a database backup file.




```
wget https://medirozahospital.com/old/mediroza_db_backup_2019.sql
```

The backup contained two tables: staff records (name, job title, department, monthly salary, plus sensitive fields such as national ID numbers that have been excluded from this report) and shareholder records (name, ownership percentage, share class). Both are reproduced below using only the non-sensitive fields relevant to this assessment.

Staff Table (name, job title, department, monthly salary)

Name	Job Title	Department	Monthly Salary (ZAR)
Dr. Rajesh Naidoo	Chief Pathologist	Diagnostics Lab	138,000
Sarah Botha	Chief Financial Officer	Finance	152,000
Dr. Johan van der Merwe	Medical Director	Management	160,000
Dr. Anita Naicker	Consultant Cardiologist	Cardiology	132,000
Dr. Ahmed Kara	Consultant Physician	Internal Medicine	128,000
Dr. Yusuf Cassim	Senior Registrar	Emergency & Trauma	74,000
Michael Roberts	HR Director	Human Resources	96,000
Susan Pretorius	HR Officer	Human Resources	32,000
Jameel Malik	IT Systems Administrator	IT	58,000
Thabo Molefe	Network Engineer	IT	46,000
Nomvula Khumalo	Registered Nurse	Emergency & Trauma	34,000
Lerato Mokoena	Registered Nurse	Pediatrics	33,000
Bongani Ndlovu	Registered Nurse	Cardiology	35,000
Zanele Mahlangu	Nursing Sister	Theatre	42,000
Kagiso Sithole	Pharmacist	Pharmacy	61,000
Naledi Zulu	Pharmacy Assistant	Pharmacy	26,000
Themba Nkosi	Radiographer	Radiology	44,000
Palesa Radebe	Radiographer	Radiology	43,000
Deepak Pillay	Lab Technologist	Diagnostics Lab	41,000
Kavitha Govender	Lab Technician	Diagnostics Lab	35,000
Dr. Suresh Moodley	Consultant Radiologist	Radiology	130,000
Dr. Fatima Patel	Pediatrician	Pediatrics	118,000
Nisha Singh	Physiotherapist	Rehabilitation	48,000
Dr. Vikram Chetty	Anaesthetist	Theatre	135,000
David Smith	Facilities Manager	Operations	52,000

Name	Job Title	Department	Monthly Salary (ZAR)
Karen O'Connor	Billing Administrator	Finance	29,000
James Wilson	Security Supervisor	Operations	27,000
Linda Fourie	Receptionist	Front Office	19,000
Peter van Wyk	Procurement Officer	Supply Chain	38,000
Andile Mbeki	Ward Clerk	Administration	21,000

Shareholder Table

Shareholder Name	Share %	Shares Held	Share Class
Dr. Rajesh Naidoo	18.0%	180,000	Ordinary
Cedar Health Holdings (Pty) Ltd	15.0%	150,000	Ordinary
Dr. Johan van der Merwe	12.0%	120,000	Ordinary
Reddy Family Trust	11.0%	110,000	Ordinary
Thabo Molefe	10.0%	100,000	Ordinary
Sarah Botha	9.0%	90,000	Ordinary
Dr. Ahmed Kara	8.0%	80,000	Preferential
Naledi Zulu	7.0%	70,000	Ordinary
Michael Roberts	6.0%	60,000	Ordinary
Dr. Vikram Chetty	4.0%	40,000	Preferential

Cross-referencing the metadata Author field (j.malik) against the staff table identifies Jameel Malik, IT Systems Administrator, as the person who created and relocated the exposed backup — completing the full attack chain from the initial login bypass to the final data exposure.

5. Risk Rating

Each finding below is rated by the real-world impact it would have on the client if exploited by a malicious actor, not merely by technical complexity.

#	Vulnerability	Location	Risk	Milestone
1	Username enumeration on login page	/patient/login.php	**Medium**	M1
2	SQL injection — login authentication bypass	/patient/login.php	**Critical**	M1
3	Encrypted PDFs accessible after login bypass	/patient/reports/	**High**	M1
4	Weak PDF passwords crackable with a wordlist	patient_report_*.pdf	**High**	M2
5	Sensitive metadata left in patient PDF files	patient_report_3.pdf	**Medium**	M3
6	Forgotten backup folder with directory listing enabled	/old/	**Critical**	M3
7	Confidential staff salaries and shareholder data exposed in plain text	/old/mediroza_db_backup_2019.sql	**Critical**	M3

Findings #2, #6 and #7 are rated Critical because each, independently, would allow a complete compromise of patient or corporate confidentiality — #2 grants full unauthorised access to the application, while #6 and #7 directly expose highly sensitive HR and ownership data with no access control whatsoever.

6. Recommendations and Remediation

1. Username enumeration: Return the same generic error message (e.g. “Invalid username or password”) regardless of which field was incorrect, so the application never confirms whether a username exists.
2. SQL injection: Rewrite all database queries to use parameterised queries or prepared statements. User input must never be concatenated directly into SQL strings.
3. PDF access control: Store patient report files outside the public web root, behind proper authenticated access controls, rather than relying on obscurity or a single login gate.
4. PDF passwords: Enforce strong, unique passwords per file rather than simple dictionary-crackable ones; consider encrypting files using a managed key rather than a shared static password.
5. PDF metadata: Strip all metadata from patient-facing files before distribution, e.g. using exiftool -all= filename.pdf, to prevent internal notes or author details from leaking.
6. Directory listing: Disable directory listing on all web server folders so file contents cannot be browsed without explicit links.
7. Backup hygiene: Remove or relocate old backup files out of any publicly accessible web folder; database backups should never be stored inside the web root.
8. General: Conduct periodic internal security reviews (recon + authentication testing + exposed-file checks) to catch this class of issue proactively rather than reactively.

7. Conclusion

This engagement demonstrates how individually moderate weaknesses — a verbose login error message, an unsanitised input field, a forgotten backup folder — can chain together into a critical, full-scale data breach. The attack path required no advanced exploitation technique: username enumeration and classic SQL injection are well-documented, easily preventable vulnerabilities, and the final data exposure stemmed from a simple server misconfiguration (directory listing) rather than a sophisticated attack.

The client should treat findings #2, #6 and #7 as immediate priorities, given their Critical rating and direct exposure of patient portal access and confidential HR/shareholder data. Addressing the recommendations above would close this entire attack chain at multiple points, significantly reducing the hospital's risk exposure.

-End-

Author
Shiwani

Cybersecurity Professional, NetworkWalks Programme (Batch B083)

Project Information
Program: Cybersecurity & Ethical Hacking at NetworkWalks | Week: 04 | Client: Mediroza General Hospital